

GESTÃO DE VULNERABILIDADES

Do caos dos 600 registros a uma visão clara de risco, prioridade e ação — usando Excel.

O desafio: quando existem centenas de vulnerabilidades, a pergunta mais importante não é “quantas existem?”, mas “onde está o risco que realmente merece atenção primeiro?”

1. O DESAFIO

A organização possui uma base com **600 registros de vulnerabilidades** e precisa transformar essa massa de dados em uma resposta prática: **onde está concentrado o maior risco e quais vulnerabilidades devem ser tratadas primeiro?**

O projeto foi construído para responder a essa pergunta sem depender de ferramentas complexas. O Excel foi usado para explorar os dados, cruzar sinais de risco, criar uma metodologia de priorização e transformar o resultado em um dashboard executivo.

Uma descoberta importante: o cenário inicial falava em 600 vulnerabilidades abertas. A base, porém, mostrou outra realidade: os 600 registros representam diferentes status, e **290 estão efetivamente como Open**. A análise seguiu os dados reais — não a suposição inicial.

2. O QUE FOI ANALISADO

A análise foi realizada exclusivamente no Excel, utilizando a tabela **tbl_Vulnerabilities**, com 600 registros e 18 campos. Entre os sinais mais relevantes estão CVSS, EPSS, CISA KEV, exposição à internet, ambiente, tipo de vulnerabilidade e status.

Foram utilizadas **Tabelas Dinâmicas, filtros, fórmulas e gráficos** para sair de perguntas genéricas e chegar a evidências concretas.

3. ONDE O RISCO COMEÇOU A APARECER

- **290** vulnerabilidades estão abertas.
- **141** das abertas estão em Production — o maior volume absoluto entre os ambientes.
- **78** vulnerabilidades abertas são Internet-facing.
- **80** vulnerabilidades combinam Open + CISA KEV + Internet Exposed.
- **66** registros possuem EPSS $\geq 50\%$.

Esses números mostram por que contar vulnerabilidades não é suficiente. O risco começa a ganhar significado quando diferentes sinais são analisados em conjunto.

4. DO DADO À DECISÃO: O RISK SCORE

Para transformar múltiplos sinais em uma leitura objetiva, foi criado um **Risk_Score** de até 15 pontos. A lógica combina cinco dimensões: severidade, probabilidade de exploração, presença no catálogo CISA KEV, exposição à internet e ambiente.

Fator	Regra	Pontos
CVSS	10,0 / 9,8 / 9,0–9,7 / 7,5–8,9	+4 / +3 / +2 / +1
EPSS	≥50% / 20–49,9% / 5–19,9% / <5%	+4 / +3 / +2 / +1
CISA KEV	Yes / No	+3 / +0
Internet Exposed	Yes / No	+2 / +0
Environment	Production / Corporate / Development	+2 / +1 / +0

Importante: esse scoring foi criado especificamente para este projeto. Ele não é apresentado como um padrão universal de gestão de vulnerabilidades.

5. RISCO NÃO É A MESMA COISA QUE PRIORIDADE

Uma decisão importante do projeto foi separar **Risk_Score** de **Priority**. O score mede o risco calculado; a prioridade traduz esse risco em uma ação operacional para as vulnerabilidades que ainda estão abertas.

Condição	Prioridade
Não está Open	Not Open
Open + Risk Score 13–15	Priority 1
Open + Risk Score 10–12	Priority 2
Open + Risk Score 7–9	Priority 3
Open + Risk Score 1–6	Priority 4

6. O QUE O MODELO ENCONTROU

- **12** vulnerabilidades abertas foram classificadas como **Priority 1**.
- O maior Risk Score encontrado entre as vulnerabilidades abertas foi **15**.
- Entre as 12 Priority 1, **12/12** possuem **CISA_KEV = Yes**.
- **11/12** possuem **Internet_Exposed = Yes**.
- **11/12** possuem **CVSS = 10**.
- **10/12** estão em **Production**.
- **3/12** possuem **EPSS ≥ 50%**.
- Remote Code Execution aparece em **7 dos 12** registros Priority 1.

7. O DESTAQUE: VULN-0302

VULN-0302

Risk Score: 15/15 · CVSS: 10 · EPSS: 69,9% · CISA KEV: Yes

Exposure: Internet-facing · Environment: Production · Status: Open

Vulnerability Type: Remote Code Execution

Esse registro reúne, dentro da metodologia criada, todos os principais sinais que elevaram sua pontuação ao máximo. Mais importante do que “encontrar um vencedor” foi construir um processo capaz de explicar **por que** determinado registro aparece no topo.

8. O DASHBOARD: QUANDO A ANÁLISE VIRA HISTÓRIA

O dashboard foi desenhado para que uma pessoa consiga entender a situação sem precisar navegar por centenas de linhas. A primeira camada mostra os números que importam; a segunda mostra onde as vulnerabilidades abertas estão concentradas; a terceira apresenta as Priority 1 para investigação e tratamento.

- KPI — Vulnerabilidades Abertas: **290**
- KPI — Vulnerabilidades Priority 1: **12**
- KPI — Maior Risk Score: **15**
- Gráfico — Vulnerabilidades abertas por Environment
- Gráfico — Vulnerabilidades abertas por Priority
- Tabela — Detalhamento das Priority 1

9. POR QUE ESSE PROJETO É RELEVANTE

O valor do projeto não está apenas nas fórmulas. Está na transformação de uma base extensa em uma narrativa de risco que pode ser explicada: **o que temos, onde está concentrado, quais sinais aumentam o risco e o que merece entrar primeiro na fila de tratamento.**

Esse é o tipo de raciocínio que aproxima uma planilha de uma ferramenta de apoio à decisão: dados → análise → modelo → prioridade → comunicação.

10. LIMITAÇÕES E CONTEXTO

- Os pesos do Risk Score foram definidos para fins deste projeto e não representam uma metodologia universal.
- O modelo não captura, por si só, impacto financeiro, criticidade específica do ativo, dependências entre sistemas ou impacto no negócio.
- EPSS, CVSS, CISA KEV e exposição representam dimensões diferentes do risco e devem ser interpretados em conjunto.
- Exposure e Internet_Exposed apresentam comportamento redundante nesta base; ambos não foram usados simultaneamente no score para evitar dupla contagem.
- As datas da base fazem parte do exercício e não foram usadas para determinar atraso em relação à data atual.

- O Risk Score é uma priorização quantitativa e deve ser complementado pelo contexto da equipe de segurança.

CONCLUSÃO

Em vez de olhar para 600 linhas e tentar decidir no escuro, o projeto criou um caminho claro para chegar às vulnerabilidades que exigem maior atenção. O resultado final é uma estrutura simples, explicável e reproduzível no Excel — construída a partir dos dados da própria base.